

R18

HTB · STARTING POINT

HTB Starting Point — Mongod

Programación para Ciberseguridad · Fase II · AD2026

MongoDB es una base de datos NoSQL ampliamente usada. Si el servidor MongoDB está configurado para escuchar en todas las interfaces sin autenticación, cualquiera con acceso a la red puede conectarse, listar colecciones y leer todos los documentos almacenados.

Objetivo: Conectarse a un servidor MongoDB sin credenciales usando `mongosh`, enumerar las bases de datos y recuperar la flag.

Acceso a la plataforma

Ve a Starting Point → Tier 0 → Mongod e inicia la máquina.

Pistas de enfoque

Escanea con `nmap` e identifica el puerto de MongoDB (27017). Conéctate con `mongosh mongodb://<IP>:27017`. Dentro del cliente, usa `show dbs`, `use <db>`, `show collections` y `db.<coleccion>.find()` para explorar.

Evidencias requeridas

- Screenshot de la conexión a MongoDB.
- Screenshot de la enumeración de bases de datos y colecciones, con la flag visible.

Preguntas de reflexión

1. En 2017, una campaña masiva borró miles de bases de datos MongoDB expuestas y pidió rescate. ¿Qué configuración por defecto de MongoDB facilitó eso, y cómo se corrigió en versiones posteriores?
2. `db.coleccion.find()` devuelve todos los documentos. ¿Cómo filtrarías solo los documentos donde un campo `tipo` sea igual a "admin"?
3. Comparando Redis (R17) y MongoDB (R18): ambos exponen datos sin autenticación. ¿En cuál de los dos sería más grave la exposición desde el punto de vista de confidencialidad de datos, y por qué?